

GDPR & Data Protection Compliance Review

Post-remediation technical review - 12 September 2026

Scope and conclusion

This is an evidence-based technical and operational review. It is not legal advice, a DPIA, certification, or a statement that the organisation is fully GDPR compliant.

The technical position has improved materially. No Critical or High unauthorised exposure of child or medical data was confirmed from repository evidence. Remaining risks are mainly organisational: approved lawful-basis wording, retention periods, request handling, processor review and owner approval.

Merged remediation

SW-79 / PR #470: public /privacy route, footer link and privacy links on Join, Parent, consent and event-consent flows. Jira: In Review pending owner approval of policy wording.

SW-80 / PR #475: auditable retention-review contract. Destructive actions require reviewer, rationale and an approved policy reference. No production deletion executor. Jira: In Review pending organisational retention decisions.

SW-83 / PR #474: email-worker diagnostics sanitised and operational recipient/test addresses removed from versioned configuration. Jira: Done.

SW-14 / PR #476: production Cloudflare Worker deployment corrected to target the existing production Worker through a dedicated top-level config. Production remains deliberate/manual.

Technical controls confirmed

Firestore and Storage rules enforce role, section, linked-parent and consent checks server-side. Sensitive consent/medical access is restricted to authorised leaders or approved linked parents. Public Who's Who data is projected separately. Default-deny patterns remain in rules.

Operational exports are minimised. Member lifecycle states support active, inactive and left. Email delivery remains fail-closed when TEST or production safeguards are not configured correctly.

Retention, transparency and processors

Retention periods are not invented in code. The Group still needs an approved schedule by data category plus an operational process for access, rectification, restriction and erasure requests.

A public privacy-information page now exists, but final wording still requires responsible-owner review. External services include Firebase/Google, Cloudflare Workers and Resend; processor/DPA and account-level settings need organisational review.

Assessment

Technical GDPR posture: materially improved and the audit-generated code remediations are merged. Organisational/legal posture: explicit policy decisions and approvals remain. Therefore this report does not claim full GDPR compliance.